Response to Reviewer 1

Enhancing Consent Policy Privacy in Blockchain-Based Healthcare Data Sharing

---

Working draft. The response text is complete for Comments 1–3. Page and line references will be added after the revised manuscript reaches final pagination.

Comments 1: *The security implications of the unbound program length should be more strongly addressed. According to the manuscript, the preimage of the commitment does not include the length of the program ℓ. Thus, a TPS that deviates from the prescribed workflow may consider a stack-consistent prefix of the committed token array instead of the full desired policy. This is not an implementation detail, but a matter of soundness. The proposed framework is oriented toward verifiable consent enforcement and therefore the authors should either bind the program length in the commitment/proof relation in the current implementation or give a much stronger justification for postponing this modification.*

Response 1: We thank the reviewer for identifying this soundness issue. We agree and have bound the program length in the commitment and proof relation in the current implementation.

In the submitted construction, the program length ℓ was used by the interpreter but was not bound to the policy commitment. A deviating TPS that knew the commitment opening could therefore attempt to evaluate a stack-consistent prefix under the commitment to the full padded token array. This can reverse an authorization outcome: for a requester satisfying A, the committed RPN program $[A, \mathrm{NOT}]$ with $\ell = 2$ denies, whereas the prefix $[A]$ with $\ell = 1$ grants.

The revised construction is

$$\begin{aligned} q &= H_{\mathrm{pol}}(P_{\mathrm{enc}}), \\ h &= \mathsf{Com}(P_{\mathrm{enc}}, \ell; r) = \mathsf{Poseidon}(q \parallel \ell \parallel r), \end{aligned}$$

where H_{pol} is the circuit's fixed-length Poseidon aggregation. The same private ℓ is supplied to both the commitment verifier and the RPN interpreter. Consequently, evaluating a different prefix would require opening h to a different (P_{enc}, ℓ) pair, which is excluded by the commitment's binding property under the collision resistance of Poseidon. The length remains private, and this modification adds no public proof input.

We added a dedicated regression suite as regression test that checks the following properties:

(i) the same padded token array and randomizer produce different commitments for different lengths;

(ii) a missing or out-of-range length is rejected;

(iii) the honest $[A, \mathrm{NOT}]$ program denies when $A = 1$;

(iv) its prefix authorizes when separately committed at length one, providing a positive control; and

(v) the truncated length cannot authorize under the commitment to the full program.

All seven regression tests pass.

The isolated circuit change adds 21 non-linear and 67 linear constraints, or 88 constraints in total (approximately 0.12% relative to the submitted 75,097-constraint circuit), and adds no public input. Thus, binding ℓ neither reveals the program length nor changes the policy-independent verification interface. Existing commitments and proving/verification keys from the submitted relation are incompatible with the revised relation and were regenerated.

Changes in the manuscript. The construction is now defined directly in the Design section, its integrity implication is distinguished from the metadata-privacy evaluation in the Discussion, and the former statement that program-length binding remained future work has been removed from the Conclusion.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Commitment Binding and Proof Generation."

> To bind each proof to a provider-defined hidden policy, the provider samples commitment randomness r uniformly from the scalar field and computes
>
> $$q = \mathsf{H}_{\mathrm{pol}}(P_{\mathrm{enc}}),$$
> $$h = \mathsf{Com}(P_{\mathrm{enc}}, \ell; r) = \mathsf{Poseidon}(q \parallel \ell \parallel r).$$
>
> Here, q is the Poseidon-based digest of the fixed-length encoded policy, ℓ is the private program length, r is the commitment randomness, and h is the policy commitment stored on-chain. The semantics of an encoded policy are determined by the pair (P_{enc}, ℓ), since ℓ identifies the active prefix of the padded token array. Accordingly, the circuit supplies the same private value ℓ to both the commitment verifier and the policy interpreter. Under the collision resistance of Poseidon, an accepting proof bound to h cannot substitute a different program length and therefore cannot evaluate an alternative stack-consistent prefix of P_{enc}.

Location in the revised manuscript: Section "Discussion."

> As described in the Design section, the policy commitment covers both the padded encoding P_{enc} and its active length ℓ. Because ℓ also determines how many tokens the interpreter evaluates, an authorizing proof for h cannot be based on a shorter valid prefix. This integrity guarantee is separate from our privacy evaluation, which measures whether public-chain artifacts reveal information about the hidden policy.

Comments 2: *The proof must be cryptographically linked to the authorization context. The current proof statement is not linked to the requester identity, protected resource, or session context. As mentioned in the manuscript, single-use of the nonce does not allow reuse of the same session parameters, but it does not prevent replay of a valid proof captured by an active party using fresh parameters. This is a significant limitation of the authorization guarantees of the current prototype. The authors would ideally add the relevant requester/resource/session values to the proved statement and experimentally evaluate the resulting circuit/public-input and gas cost changes. If this cannot be implemented in the current version, the security claims and deployment implications should be made even more explicit throughout the manuscript, including the abstract and conclusion.*

Response 2: We thank the reviewer for identifying this authorization-context gap. We agree and have implemented the proposed binding in both the circuit and the on-chain access-control path.

In the submitted system, the public statement contained the authorization output, policy commitment, and parameter commitment, but no value derived from the requester, resource, or session. The contract checked nonce reuse only from the transaction parameters. Consequently, a captured proof could be paired with a fresh nonce or another resource while the proof itself remained unchanged.

For the revised construction, let

$$\chi = (id_{\text{req}}, id_{\text{res}}, \nu), \qquad d_\chi = \mathsf{Poseidon}(id_{\text{req}} \parallel id_{\text{res}} \parallel \nu),$$

where ν is the session nonce. The circuit takes the three components of χ as private circuit inputs and enforces the hard equality $d_\chi = \mathsf{Poseidon}(\chi)$, with d_χ exposed as a public input. The ACM receives the same three values as transaction parameters, recomputes the digest on-chain, and requires it to equal the proof's public signal before verification. It also checks the resource–policy association, the public request epoch, and nonce single-use for the tuple $(\mathit{policy}, \mathit{resource}, \nu, id_{\text{req}})$. Thus, within one ACM deployment, changing the requester identifier, resource, or nonce causes rejection.

The three context values are private with respect to the Groth16 relation but are not hidden from the blockchain: they are present in transaction calldata so that the ACM can recompute the digest. We therefore describe id_{req} as a requester identifier or pseudonym, not as a hidden or universally authenticated real-world identity. The current statement contains five signals:

$$(1, h, pp, d_\chi, \tau),$$

namely one output and four public inputs; τ is a separate request-epoch input added for temporal policy checks.

We measured the context-binding change in isolation against the length-bound circuit immediately preceding it. It adds 605 R1CS constraints, increasing the total from 75,185 to 75,790 (0.8%), and adds one public input.

The revised implementation is covered at both layers. At the circuit layer, the test rejects a context digest computed for another nonce. At the contract layer, the tests confirm agreement between the circuit-side and EVM Poseidon implementations and reject substitutions of the requester, resource, and nonce. The end-to-end suite reuses one valid proof as a negative control and confirms that a fresh nonce or another resource governed by the same policy fails with a context-binding mismatch. All targeted tests pass.

We have kept the claim precise: the change closes the reviewer's fresh-parameter replay within one ACM deployment. The digest does not currently include the transaction submitter or a chain/contract domain, so the revised Discussion identifies exact-context front-running and cross-deployment reuse as separate hardening considerations.

Changes in the manuscript. The Design section now defines the context digest and the five-signal statement, explains the circuit and ACM checks, and removes the former future-work language. The Problem and Threat Model section now distinguishes the issuer-authenticated profile claims from other evidence, separates the pseudonymous requester identifier from real-world identity and issuer governance, and identifies adaptive requester probing and off-chain side channels as outside the present evaluation. The Discussion reports the measured marginal cost and states the scope of the resulting guarantee. The cost profile now reports the final RC1 circuit and public interface together with the revised Polygon Amoy gas, calldata, and prover measurements.

Location in the revised manuscript: Section "Problem and Threat Model," subsection "System and Trust Model."

Attribute-origin guarantees depend on the evidence type. For profile-backed DUO terms, the prototype verifies an EdDSA-Poseidon credential under the issuer-key commitment selected in the policy parameters. The signed claims are bound to the policy commitment, requester pseudonym, protected resource, validity interval, and credential identifier, and the corresponding policy attributes are derived from those claims inside the circuit. This guarantee is not universal: ontology checks prove membership in a provider-committed code set, and requester allowlists prove inclusion of a holder pseudonym in a provider-committed list, but neither mechanism independently establishes a requester's real-world identity or the external origin of every submitted value. The authority and correct provisioning of an issuer key, the truthfulness of issuance, credential revocation, and real-world identity verification therefore remain external trust and lifecycle functions.

Location in the revised manuscript: Section "Problem and Threat Model," subsection "Public-Chain Adversary."

Adaptive requester probing and off-chain side channels are outside the scope of the present evaluation. The proved authorization outcome is bound to a pseudonymous requester identifier, a protected resource, and a session nonce through the context digest defined in the Design section. This binding prevents substitution of the recorded authorization context, but it should not be interpreted as proof of the requester's real-world identity.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Commitment Binding and Proof Generation."

For an access request, let

$$\chi = (id_{\text{req}}, id_{\text{res}}, \nu), \qquad d_\chi = \mathsf{Poseidon}(id_{\text{req}} \parallel id_{\text{res}} \parallel \nu),$$

where ν is a fresh session nonce. The TPS constructs the private circuit witness

$$w = (P_{\text{enc}}, \ell, a, b, r, \omega, \chi).$$

The context tuple χ consists of private circuit inputs, while its digest d_χ is public. The current public-signal vector is

$$(1, h, pp, d_\chi, \tau),$$

where pp is a fixed-format commitment to the per-predicate parameters and τ is the request epoch used by the temporal checks. Although the three components of χ are not separate Groth16 public inputs, the ACM receives them as transaction parameters in order to recompute d_χ; they are therefore visible in transaction calldata. The TPS generates a proof

$$\pi \leftarrow \mathsf{Prove}(pk, w; (1, h, pp, d_\chi, \tau)).$$

The proof certifies the conjunction that $C(P_{\text{enc}}, \ell, (a, b)) = 1$, $h = \mathsf{Com}(P_{\text{enc}}, \ell; r)$, $d_\chi = \mathsf{Poseidon}(\chi)$, and required external-predicate checks are internally consistent with respect to the supplied parameters and placeholder gadgets. Before verifying π, the ACM checks that the resource is governed by the stated policy, that τ is current, that the nonce has not been used for the same requester–resource context, and that the digest recomputed from the transaction parameters equals the public signal d_χ. Thus, within one ACM deployment, a proof generated for one requester identifier, resource, and nonce cannot be accepted under a different tuple.

Location in the revised manuscript: Section "Discussion."

> The circuit constrains the public digest d_χ to the requester identifier, resource, and nonce used in the witness, and the ACM recomputes the same digest from the transaction parameters. Consequently, changing any of these values invalidates the request.

Location in the revised manuscript: Section "Evaluation," cost profile table.

> Circuit size: 81,740 R1CS constraints and 80,884 wires at DEPTH = 64. Public interface: four public inputs plus one output. Across the 1,773 revised Polygon Amoy executions, mean padded gas is 304,167 for commit and 1,057,283 for access; the fixed calldata lengths are 196 and 612 bytes, respectively.

Comments 3: *The problem of attribute-origin requires further investigation. The issuer-signature mechanism is a placeholder for consistency, based on Poseidon, and thus does not provide cryptographic unforgeability as it stands. Thus, the proof proves the consistency of the given witness but does not prove that the private attributes are derived from an authorized issuer. This difference is particularly important in a healthcare authorization system. The authors should clarify which authorization properties are guaranteed by the prototype they implemented, and which are dependent on external trust. Even an analytical assessment of a concrete design for the integration of real credential verification would greatly improve the work.*

Response 3: We thank the reviewer for emphasizing this distinction. We agree that witness consistency alone is insufficient to establish attribute origin, and that a healthcare authorization prototype must separate cryptographic credential verification from trust in the real-world issuer.

During the revision, we clarified and documented the implemented in-circuit EdDSA-Poseidon verification path for a credential carrying fixed DUO-relevant claims. For the private, issuer-signed claim bits $c_0, \ldots, c_6$ for, respectively, research use, health or medical use, methods development, genetic study, ancestry, commercial use, and non-profit use, let d_{DUO} denote the fixed credential schema/domain tag. The circuit reconstructs

$$m_{\mathrm{cred}} = \mathsf{Poseidon}(d_{\mathrm{DUO}} \parallel h \parallel id_{\mathrm{req}} \parallel id_{\mathrm{res}} \parallel c_0 \parallel \cdots \parallel c_6 \parallel t_{\mathrm{from}} \parallel t_{\mathrm{until}} \parallel \gamma)$$

Before proof generation, an issuer computes $\sigma \leftarrow \mathsf{Sign}_{\text{EdDSA-Poseidon}}(s_{\mathrm{iss}}, m_{\mathrm{cred}})$ with its private signing key s_{iss}. The resulting credential is supplied to the TPS as private off-chain evidence for proof generation. At proof generation, the TPS supplies the credential as private witness and the circuit verifies the issuer's EdDSA-Poseidon signature on this message. It also constrains the supplied issuer point to the issuer-key commitment contained in the policy-bound parameters, enforces the credential validity interval and a non-zero credential identifier, and, for a policy that activates this holder-bound credential slot, binds the requester pseudonym to a holder secret. The circuit derives the DUO terms GRU, HMB, NMDS, GSO, NPUNCU, NPOA, NPU, and NCU from these signed claims. Under the unforgeability of EdDSA for correctly generated Baby Jubjub keys and the collision resistance of Poseidon, a TPS cannot modify the signed policy, requester, resource, claims, validity interval, or credential identifier and still produce an accepting proof.

We have also narrowed the claim carefully. The prototype proves signature validity under a policy-selected issuer key; it does not prove that this key belongs to an accredited hospital, ethics board, or other healthcare authority. The provider currently selects the issuer-key commitment, and there is no independently governed issuer registry or credential-revocation check.

Ontology predicates prove that a supplied code belongs to a provider-committed set, while requester allowlists prove that a holder pseudonym belongs to a provider-committed list; neither mechanism independently authenticates every associated real-world fact. Furthermore, the current TPS receives the holder secret and credential witness, so holder binding does not protect against a malicious TPS reusing otherwise valid evidence within its signed scope. The Polygon Amoy evaluation uses a deterministic test-only issuer key to exercise the cryptographic path and measure the complete system; it is not evidence of institutional issuance or production key management.

We added an analytical production-integration design to the Discussion. A governed issuer registry would publish schema-qualified, time-bounded issuer keys and require canonical encoding, subgroup validation, and proof of possession at registration. The issuer would sign a domain-separated credential containing a holder-key commitment, claims, authorization scope, validity interval, and credential identifier. The circuit would verify the credential signature and private membership of the issuer key in the active registry. The holder would retain its secret and sign the authorization context for each session, preventing the TPS from creating fresh-session proofs from a captured credential presentation. An epoch-specific sparse-Merkle or accumulator root would additionally support private non-revocation proofs. These roots can be folded into a fixed-format state commitment, preserving the policy-independent public interface. For credentials using Ed25519, ECDSA, or another non-circuit-friendly signature, the alternatives are to pay the higher in-circuit verification cost or have the issuer additionally issue a SNARK-friendly credential; TPS re-signing would not preserve issuer-origin assurance.

The implemented credential path is covered by the DUO profile and tamper suites. The targeted tests accept a correctly signed credential and reject a non-committed issuer, a forged signature under the committed key, credentials outside their validity interval, substitutions of the policy, requester, resource, or signed claims, inconsistent derived attributes, and an invalid holder binding. All 25 targeted tests pass, including full Groth16 proof and on-chain grant/deny cases, and the frozen manifest, verifier ABI, and cryptographic artifacts validate successfully.

Changes in the manuscript. The Problem and Threat Model now separates issuer-signed profile claims from ontology and allowlist evidence and states the remaining issuer-governance, revocation, identity, and TPS trust assumptions. The Design section replaces the obsolete placeholder description with the implemented credential relation and its exact scope. The Discussion distinguishes cryptographic signature validity from real-world issuer authorization and presents a concrete registry, holder-proof, and revocation integration design.

Location in the revised manuscript: Section “Problem and Threat Model,” subsection “System and Trust Model.”

> Attribute-origin guarantees depend on the evidence type. For profile-backed DUO terms, the prototype verifies an EdDSA-Poseidon credential under a provider-selected, policy-bound issuer-key commitment. The credential binds the policy commitment, requester pseudonym, protected resource, claims, validity interval, and credential identifier; the corresponding policy attributes are derived inside the circuit. Thus, subject to signature unforgeability and Poseidon collision resistance, these values cannot be modified without invalidating the proof. This guarantee does not establish the real-world authority of the issuer or the truthfulness of issuance. Ontology and requester-allowlist predicates likewise establish membership only relative to provider-committed sets. Issuer-key governance, credential revocation, real-world identity verification, and protection against a compromised TPS remain external trust and lifecycle functions.

Location in the revised manuscript: Section "TPS-ZKPI Design," subsection "Credential-Origin Binding."

> Let $c_0, \ldots, c_6$ be the seven private, issuer-signed claim bits for research use, health or medical use, methods development, genetic study, ancestry, commercial use, and non-profit use, respectively. Let d_{DUO} be the fixed credential schema/domain tag. The circuit derives the DUO terms GRU, HMB, NMDS, GSO, NPUNCU, NPOA, NPU, and NCU from these claims. For issuer public key $A = (A_x, A_y)$, the circuit reconstructs the domain-separated message
>
> $$m_{\mathrm{cred}} = \mathsf{Poseidon}(d_{\mathrm{DUO}} \parallel h \parallel id_{\mathrm{req}} \parallel id_{\mathrm{res}} \parallel c_0 \parallel \cdots \parallel c_6 \parallel t_{\mathrm{from}} \parallel t_{\mathrm{until}} \parallel \gamma)$$
>
> Before proof generation, an issuer holding the corresponding private signing key s_{iss} issues the credential by computing $\sigma \leftarrow \mathsf{Sign}_{\text{EdDSA-Poseidon}}(s_{\mathrm{iss}}, m_{\mathrm{cred}})$. The resulting credential is supplied to the TPS as private off-chain evidence for proof generation. At proof generation, the TPS supplies A, σ, and the credential fields as private witness values. The circuit then enforces
>
> $$\mathsf{Verify}_{\text{EdDSA-Poseidon}}(A, \sigma, m_{\mathrm{cred}}) = 1, \qquad \mathsf{Poseidon}(A_x \parallel A_y) = k_{\mathrm{iss}}.$$
>
> The circuit additionally requires
>
> $$t_{\mathrm{from}} \le \tau \le t_{\mathrm{until}}, \qquad \gamma \neq 0,$$
>
> For a policy that activates this holder-bound credential slot, it also requires $id_{\mathrm{req}} = \mathsf{Poseidon}(s_{\mathrm{holder}})$, binding the credential to the pseudonymous requester identifier in the authorization context. The corresponding DUO attributes are constrained to these claim-derived values rather than accepted independently from the prover. This is a cryptographic signature check, not a hash-consistency placeholder.

Location in the revised manuscript: Section "Privacy Evaluation," subsection "Dataset and corpus generation."

> For reproducibility, the evaluation generator uses a deterministic test issuer to create the private profile-credential witnesses used by policies that exercise the credential predicate; this testing key does not model issuer governance or production key management.

Location in the revised manuscript: Section "Discussion."

> The remaining trust anchor is therefore issuer governance rather than signature consistency. The prototype binds the proof to a policy-selected issuer-key commitment, but it has no independent registry establishing that this key belongs to an accredited healthcare authority, and it does not check credential revocation. A concrete deployment can close this gap without changing the Boolean interpreter. A governed issuer registry would publish schema-qualified issuer keys and their validity epochs; the circuit would verify both the credential signature and a Merkle proof that the issuer key is active in the registry. The holder would retain its secret key and authorize each request by signing the context digest and request epoch, while an epoch-specific sparse-Merkle or accumulator root would support a private non-revocation witness for the credential identifier.